

SİBER SALDIRI ANALİZİ

1-)Fidye Yazılımı Saldırısı (Ransomware): Özellikle kritik altyapıyı veya büyük kurumları hedef alan, yüksek fidye talepli bir olay.

2-)Tedarik Zinciri Saldırısı (Supply Chain Attack): Güvenilir bir yazılım veya hizmet üzerinden birden fazla kuruluşa sızma.

3-)Büyük Ölçekli Veri İhlali (Massive Data Breach): Milyonlarca kullanıcının kişisel verilerinin çalınması.

1. Saldırı: Fidye Yazılımı Saldırısı (Ransomware) - Kritik Altyapı Hedefi

Bu tür saldırılar, genellikle bir kurumun operasyonlarını tamamen durdurarak en büyük finansal ve itibar kaybına yol açan saldırı türlerinden biridir. Seçtiğimiz örnek, 2024 yılında imalat sektöründe (raporlarda en çok saldırıya uğrayan sektör olarak belirtilmiştir) veya kritik bir altyapıda gerçekleşmiş yüksek profilli bir fidye yazılımı saldırısıdır.

Saldırı Türü: Fidye Yazılımı (Ransomware). Saldırganlar, hedefin kritik sistemlerini şifreleyerek erişimi engeller ve karşılığında fidye talep ederler. Modern fidye yazılımı saldırıları genellikle **çift şantaj (double extortion)** yöntemini kullanır; yani veriyi hem şifrelerler hem de çalarlar. Fidye ödenmezse veriler sızdırılmakla tehdit edilir.

Kullanılan Yöntemler:

1.Zayıf RDP (Uzak Masaüstü Protokolü) veya VPN Şifreleri: Saldırganlar genellikle internete açık ve zayıf parolalarla korunan Uzak Masaüstü veya VPN hizmetlerini tarayarak ilk erişimi sağlarlar.

2.Oltalama (Phishing) veya Spear Phishing: Kritik personele özel olarak hazırlanmış sahte e-postalar gönderilerek kimlik bilgileri çalınır veya zararlı bir dosyanın çalıştırılması sağlanır.

3.Yazılım Zafiyetleri (Vulnerability Exploitation): Özellikle yama yapılmamış kritik sunuculardaki (örneğin e-posta sunucuları, ağ cihazları) bilinen veya sıfırinci gün (zero-day) zafiyetleri kullanarak ağa sızarlar.

4.Yatay Hareket (Lateral Movement): İlk erişimi sağladıktan sonra, ağ içindeki güvenlik açıklarından veya ele geçirilmiş kimlik bilgilerinden yararlanarak, ayrıcalıklı hesaplara ulaşır ve etki alanının kontrolünü (Domain Controller) ele geçirerek şifreleme yazılımını tüm sisteme dağıtırlar.

Sektörel Etki (İmalat/Kritik Altyapı):

***Üretim Durması:** Şifreleme nedeniyle üretim hatları, tedarik zinciri yönetimi (SCM) sistemleri ve otomasyon sistemleri durur. Her saatlik duruş, milyonlarca dolarlık kayba, sözleşme cezalarına ve teslimat gecikmelerine neden olur.

***Tedarik Zinciri Aksaklığı:** Büyük bir imalatçının durması, küresel tedarik zincirinde domino etkisi yaratır; parçaların veya nihai ürünlerin akışı kesilir.

***Güven Kaybı:** Şirket, müşterileri ve tedarikçileri nezdinde operasyonel güvenilirliğini kaybeder.

Dünya Çapında Yankı: Kritik altyapıya veya temel hizmetlere (sağlık, enerji, gıda) yönelik saldırılar, ulusal güvenlik meselesi olarak görülür. Devletler arası ilişkileri etkileyebilir ve siber güvenliğin birincil risk olarak kabul edilmesine yol açar. Gündem, fidyenin ödenip ödenmemesi, saldırganların kimliği ve olası devlet destekli bağlantıları üzerine odaklanır.

Teknik ve Finansal Sonuçları

Teknik Sonuçlar

Tüm sunucu ve iş istasyonlarının şifrelenmesi. Verilerin erişilemez hale gelmesi. Yedeklemelerin de (eğer ağa bağlıysa) hedef alınarak yok edilmesi. Sistemlerin kurtarılması için aylarca sürebilecek temizleme, yeniden kurma ve doğrulama süreci. Tüm ağın ve kimlik doğrulama altyapısının sıfırdan güvenli hale getirilmesi ihtiyacı.

Finansal Sonuçlar

Fidye Ödemesi: Milyonlarca doları bulabilir (eğer ödenirse). **Operasyonel Kayıplar:** Üretim duruşlarından kaynaklanan milyarlarca dolarlık gelir kaybı ve ceza ödemeleri. **Kurtarma Maliyeti:** BT uzmanları, adli bilişim ve kriz yönetimi danışmanlığı için yüksek harcamalar. **Dava ve Regülasyon Cezaları:** Veri sızıntısı varsa GDPR gibi regülasyonlar uyarınca çok büyük para cezaları.

CIA Üçgeni İhlali

Erişilebilirlik (Availability): En büyük ihlal budur. Kritik sistemler şifrelenerek tamamen erişilemez hale gelir, bu da iş sürekliliğini durdurur.

Çıkarılan Dersler: Zayıf dışa dönük hizmet güvenliği (RDP/VPN) ana giriş kapısıdır. Tek başına geleneksel yedeklemeler yeterli değildir; yedeklemeler çevrimdışı (air-gapped) veya değişmez (immutable) olmalıdır. Ağ içi segmentasyon (bölümlendirme) eksikliği, saldırganların kolayca yayılmasına izin verir.

Alınabilecek Önlemler:

- 1.Güçlü Kimlik Doğrulama:** İnternete açık tüm hizmetlerde (VPN, RDP) **Çok Faktörlü Kimlik Doğrulama (MFA)** zorunlu hale getirilmeli.
- 2.Ağ Segmentasyonu:** Ağ, kritik sistemleri izole edecek şekilde küçük, izole bölümlere ayrılmalı. Saldırganın bir bölgeden diğerine geçmesi engellenmeli.
- 3.Çevrimdışı Yedekleme Stratejisi (3-2-1 Kuralı):** Verinin 3 kopyası, 2 farklı ortamda ve en az 1 tanesi çevrimdışı/değişmez depoda tutulmalı.
- 4.Uç Nokta Algılama ve Yanıt (EDR/XDR):** Gelişmiş saldırı davranışlarını şifreleme başlamadan önce tespit edip durduracak çözümler kullanılmalı.

2. Saldırı: Tedarik Zinciri Saldırısı (Supply Chain Attack) - Yazılım Güvenliği İhlali

Tedarik zinciri saldırıları, bir şirketin kullandığı üçüncü taraf yazılımları veya hizmetleri hedef alarak, bu güven ilişkisi üzerinden asıl hedef organizasyona sızma yöntemidir. 2020'deki SolarWinds saldırısı bu türün en bilinen örneğidir, ancak bu tür saldırılar hala küresel gündemin önemli bir parçasıdır.

Saldırı Türü: Tedarik Zinciri Saldırısı (Supply Chain Attack). Saldırgan, binlerce müşterisi olan popüler ve güvenilir bir yazılım geliştiricisinin sistemlerine sızar.

Kullanılan Yöntemler:

- 1.Kaynak Kod Manipülasyonu:** Saldırgan, yazılımın orijinal kaynak koduna veya derleme (build) sürecine gizlice zararlı bir arka kapı (backdoor) ekler.
- 2.Zafiyet (Zero-Day) veya Zayıf Kimlik Doğrulama:** Yazılım şirketinin kendi ağındaki zafiyetler veya zayıf erişim kontrol mekanizmaları kullanılarak geliştirme ortamına erişim sağlanır.

3.Güncelleme Mekanizmasının Zehirlenmesi: Zararlı kod, meşru bir yazılım güncellemesi olarak imzalanır ve otomatik güncellemeler aracılığıyla binlerce müşterinin ağına ve sistemine sessizce yayılır.

Sektörel Etki (Çoklu Sektör): Tek bir siber güvenlik veya BT yönetim yazılımının etkilenmesi, **hükümet ajanslarından** (Kamu), **finans kurumlarına** (Finans), **teknoloji devlerine** (Bilgi/Bilişim) kadar çok geniş bir yelpazeyi anında etkiler. Saldırının doğası gereği, en çok etkilenen sektörler BT yönetimine yoğun bağımlılığı olan sektörlerdir.

***Güven Yıkımı:** Müşteriler, artık güvendiği satıcının yazılım güncellemelerinin bile tehdit taşıyabileceğini fark eder. Bu, tüm yazılım tedarik zincirine duyulan güveni temelden sarsar.

***Gizli ve Uzun Süreli Sızma:** Saldırganlar, tespit edilmeden aylarca, hatta yıllarca kurbanların ağlarında kalabilir ve veri toplayabilir.

***Dünya Çapında Yankı:** Bir tedarik zinciri saldırısı, genellikle bir casusluk operasyonu olarak algılanır ve devletler arası gerilime neden olur. NATO, AB ve diğer uluslararası kuruluşlar, tedarik zinciri güvenliğini öncelikli gündem maddesi haline getirir.

Teknik ve Finansal Sonuçları

Teknik Sonuçlar

Binlerce kurbanın ağına arka kapı yerleştirilmesi. Kritik sunucuların ve e-posta sistemlerinin gizlice izlenmesi. Yüksek değerli fikri mülkiyetin (IP) veya devlet sırlarının çalınması. Tüm etkilenen sistemlerin tek tek incelenip arka kapının temizlenmesi. Yazılım geliştirme süreçlerinin ve altyapısının sıfırdan yeniden güvenli hale getirilmesi.

Finansal Sonuçlar

İtibar Kaybı: Yazılım şirketinin piyasa değeri ve müşterileri nezdindeki itibarı ciddi zarar görür. **Temizleme ve Kurtarma Maliyeti:** Müşterilerin kendi sistemlerini temizlemesi için harcadığı çok büyük BT maliyetleri. **Yasal Maliyetler:** Dava süreçleri, regülatör incelemeleri ve milyarlarca dolarlık potansiyel tazminat yükü. **İş Kaybı:** Güvenilirliğini kaybeden tedarikçi, büyük müşterilerini kaybedebilir.

CIA Üçgeni İhlali

Gizlilik (Confidentiality): En büyük ihlaldir. Saldırı, casusluk amacıyla yapıldığı için, ağlardaki kritik veriler, e-postalar ve dökümanlar tespit edilmeden çalınır veya izlenir.

Çıkarılan Dersler: En güvendiğiniz üçüncü taraf yazılımlara bile körü körüne güvenilmemesi gerektiği ("Sıfır Güven" yaklaşımı). Yazılım geliştirme ve derleme ortamlarının, bir şirketin en çok korunan yerlerinden biri olması gerektiği.

Alınabilecek Önlemler:

1.Sıfır Güven (Zero Trust) Mimarisi: Ağın içindeki hiçbir kullanıcı veya uygulamanın otomatik olarak güvenilir kabul edilmemesi. Her erişim isteğinin sürekli doğrulanması.

2.Yazılım Bileşen Analizi (SBOM): Kullanılan yazılımın tüm bileşenlerinin (açık kaynak dahil) bir listesinin (SBOM - Software Bill of Materials) tutulması ve güvenlik açısından taranması.

3.Geliştirme Ortamı İzolasyonu: Yazılımın geliştirildiği ve güncellemelerin imzalandığı sunucuların en katı güvenlik protokolleriyle korunması ve internetten izole edilmesi.

4.Tedarikçi Risk Yönetimi: Kritik tedarikçilerin siber güvenlik olgunluğunun düzenli olarak denetlenmesi.

3. Saldırı: Büyük Ölçekli Veri İhlali (Massive Data Breach) - Kimlik Bilgileri Hırsızlığı

Bu tür saldırılar, genellikle bir e-ticaret platformu, sosyal medya şirketi veya telekomünikasyon şirketi gibi büyük bir tüketici veri tabanını hedef alır ve doğrudan bireylerin gizliliğini ihlal eder.

Saldırı Türü: Büyük Ölçekli Veri İhlali (Massive Data Breach). Milyonlarca müşteriye ait Kişisel Olarak Tanımlayıcı Bilgilerin (PII) veya hassas müşteri verilerinin (ad, soyad, e-posta, telefon, adres, şifrelerin hashleri vb.) çalınması.

Kullanılan Yöntemler:

1.SQL Enjeksiyonu (SQL Injection): Saldırgan, web uygulaması üzerinden veri tabanına zararlı sorgular göndererek veri tabanındaki tüm veriyi çeker.

2.Yanlış Yapılandırma (Misconfiguration): Bulut depolama kovalarının (bucket) veya veri tabanı sunucularının yanlış yapılandırılması sonucu, internetten kimlik doğrulamaya gerek kalmadan erişilebilir hale gelmesi.

3.Oltalama (Phishing) ve Zayıf Parola: Bir çalışanın kimlik bilgilerini çalınarak kurumsal ağa sızma ve ardından veri tabanına ulaşma.

4.API Zafiyetleri: Uygulama Programlama Arayüzlerinde (API) yetkilendirme kontrolü eksikliği (BOLA - Broken Object Level Authorization) nedeniyle, bir kullanıcının kendi verisi yerine diğer tüm kullanıcıların verisine erişebilmesi.

Sektörel Etki (E-Ticaret/Telekom/Finans):

***Müşteri Kaybı:** Tüketiciler, verileri çalınan platformlara olan güvenlerini kaybeder ve rakip hizmetlere geçer.

***İkincil Saldırıları:** Çalınan kimlik bilgileri, diğer platformlardaki (bankacılık, e-posta) hesaplara karşı parola tekrar kullanımı (credential stuffing) saldırıları için kullanılır.

***Finansal Dolandırıcılık:** Kimlik bilgileriyle desteklenen oltalama e-postaları veya kimlik hırsızlıkları artar.

Dünya Çapında Nasıl Duyuruldu: Saldırı, regülatörler (örneğin GDPR'ı uygulayan kurumlar) tarafından hemen incelemeye alınır. Milyonlarca kişinin aynı anda kimlik doğrulama bilgilerini değiştirmesi gerekir. Medyada günlerce "şimdiye kadarki en büyük ihlal" başlıklarıyla yer alır ve bu, siber güvenlik bilincinin artmasına neden olur.

Teknik Veri tabanı sunucusunun saldırı sonrası temizlenmesi ve yapılandırılması.

Sonuçlar Veri tabanı şifreleme ve maskeme mekanizmalarının eklenmesi.

Sonuçlar Uygulama kodundaki (örneğin SQL enjeksiyonu zafiyeti olan kısımların) kökten düzeltilmesi. Kullanıcıların şifrelerini sıfırlama zorunluluğu.

Regülasyon Cezaları: GDPR, CCPA gibi veri koruma kanunları kapsamında şirketin küresel cirosunun %4'üne kadar çıkabilen devasa cezalar. **Dava**

Finansal Masrafları: Toplu davalar (Class-Action Lawsuits) ve milyonlarca müşteriye

Sonuçlar yönelik tazminat ödemeleri. **Müşteri Bildirim Maliyetleri:** Etkilenen tüm müşterilere bildirim gönderme, kredi izleme hizmeti sunma maliyeti. **İtibar**

Değeri Kaybı: Marka değeri üzerinde uzun vadeli olumsuz etki.

CIA Üçgeni İhlali ilkesi

Gizlilik (Confidentiality): En büyük ihlaldir. Müşterilerin hassas ve kişisel verileri yetkisiz üçüncü tarafların eline geçmiştir.

Çıkarılan Dersler: Uygulama güvenliğine (özellikle web ve API) yeterince yatırım yapılmadığı. Hassas verilerin (özellikle şifreler) doğru bir şekilde hashlenmediği/şifrelenmediği. Veri tabanı erişim kontrolünün yetersiz olduğu.

Alınabilecek Önlemler:

1.Güvenli Kodlama Pratikleri (Secure Coding): Geliştiricilerin SQL enjeksiyonu gibi yaygın web zafiyetlerine karşı eğitilmesi ve kodun otomatik araçlarla taranması.

2.Veri Şifreleme ve Maskeleye: Veri tabanında depolanan tüm hassas verilerin (PII) şifrelenmesi ve geliştirme/test ortamlarında gerçek verilerin maskelenmesi.

3.Web Uygulama Güvenlik Duvarı (WAF): Uygulama katmanı saldırılarını (SQL Injection, XSS vb.) engellemek için WAF kullanımı.

4.En Az Ayrıcalık Prensibi: Veri tabanı sunucularına sadece ihtiyacı olan uygulama ve BT personelinin, sadece gereken veri kümelerine erişimini sağlamak. Kullanıcı parolalarını güçlü, tek yönlü şifreleme algoritmaları (örneğin Argon2, Bcrypt) ile saklamak.